武汉大学 国家网络安全学院
SCHOOL OF CYBER SCIENCE AND ENGINEERING·WHU

信息系统安全

（Information System Security）

武汉大学
王鹃

jwang@whu.edu.cn

目录

- 信息系统安全概述
- 软件安全与恶意代码
- 渗透测试方法及工具
- 模糊测试与漏洞挖掘
- 用户身份认证机制
- 访问控制模型
- 操作系统基础安全机制
- 硬件安全与可信计算
- 系统风险评估方法与工具
- 信息系统安全研究新方向

第十章 信息系统安全研究新方向

LISS
空天信息安全与可信计算
教育部重点实验室

信息系统安全研究新方向

1、 信息安全研究热点

2、 云计算安全

3、 移动安全

4、 物联网安全

5、 系统安全研究基础

LISS
空天信息安全与可信计算
教育部重点实验室

信息系统安全研究热点

信息安全四大顶级会议

- S&P-IEEE Symposium On Security and Privacy
- CCS-ACM Conference on Computer and Communications Security
- USENIX Security Symposium
- NDSS-Network and Distributed System Security Symposium

其它著名安全会议和杂志

- RSA
- Blackhat
- Defcon
- TDSC（ IEEE Transactions on Dependable and Secure Computing ）-CCF A
- TIFS（IEEE Transactions on Information Forensics and Security）-CCF A

四大会研究热点

- S&P 2020 40th
  - Hardware Security- Microarchitectural Security
  - Web and Cloud Security
  - Mobile Security
  - Program Analysis
  - Machine Learning and Privacy
  - Fuzzing
  - Systems and Applied Security
  - IoT Security
  - Blockchain

LISS
空天信息安全与可信计算
教育部重点实验室

四大会研究热点

- **USENIX Security 29th**
  - Software Security and Verification
  - Network Security
  - Mobile
  - Web Security and Privacy
  - Trusted Execution Environments
  - Automotive and Drone Security
  - Privacy Enhancing Technologies
  - Embedded/IoT Security
  - Machine Learning

LISS
空天信息安全与可信计算
教育部重点实验室

四大会研究热点

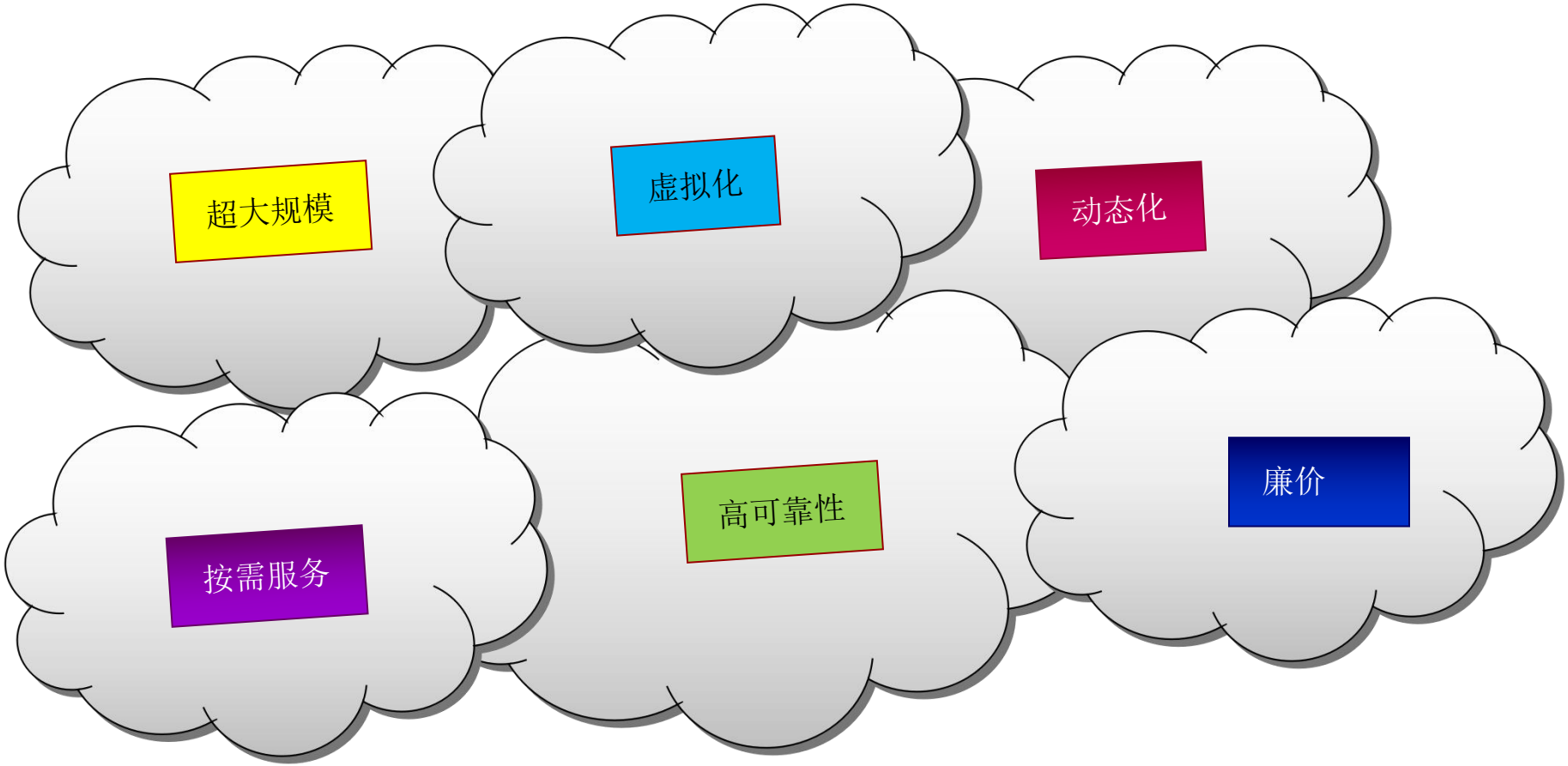
- CCS 2019 **26nd**
  - Attacking and Defending ML Systems
  - ML and Information Leakage
  - Binary Analysis/Policy and Access Control
  - Anonymous Routing and Censorship
  - Applied Cryptography and Cryptanalysis
  - Cyberphysical Systems
  - Browser Security
  - Mobile Security
  - Smart Contracts and Cryptocurrencies

LISS
空天信息安全与可信计算
教育部重点实验室

云计算的概念

- 云计算（ wikipedia ）
  - 云计算是这样一种计算方式，计算资源是动态易扩展而且虚拟化的，往往通过互联网提供。用户不需要了解“云”中基础设施的细节，不必具有相应的专业知识，也无需直接进行控制。
  - 云计算的核心技术是虚拟化技术

云计算的特征



云计算提供的服务类型

- 云计算对外提供的服务包括三种类型：IaaS、PaaS和SaaS

- ✓ **SaaS**：通过网络向最终用户提供软件应用服务。

- ✓ **PaaS**：通过网络向用户提供可定制，可开发的平台服务。 例如应用开发环境、数据库服务等。

- ✓ **IaaS**：通过网络为用户提供IT基础设施服务。包括计算、存储和网络资源出租等服务。

LISS
空天信息安全与可信计算
教育部重点实验室

云的类型

公共云

面向大众开放

随需定制，按需付费

云杀毒，云盘，云办公等

私有云

公司或者单位内部的数据中心，供内部员工使用，不对外开放

内部服务器

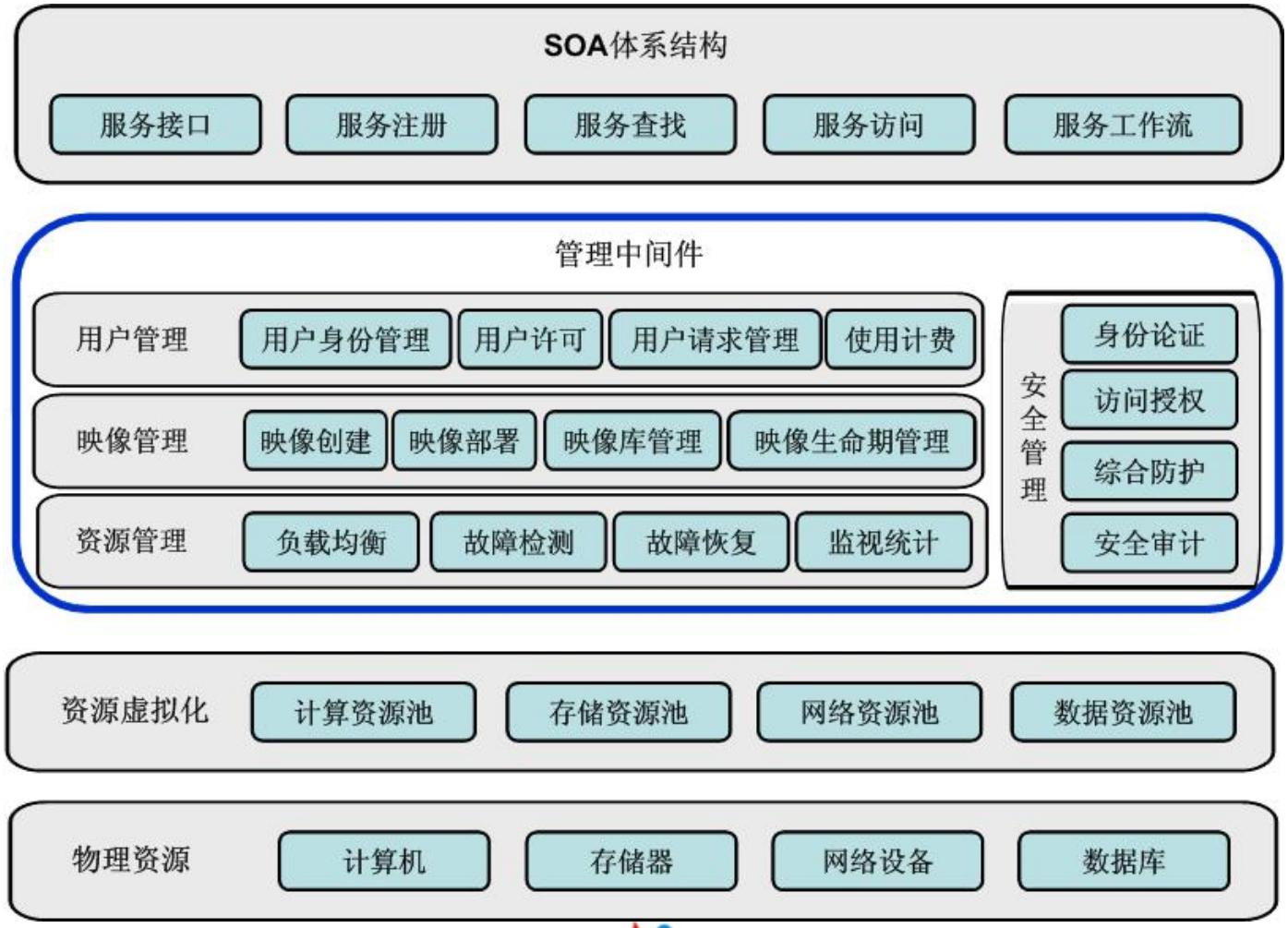
混合云

将公共云与私有云结合起来

提供公共接口和私密性服务

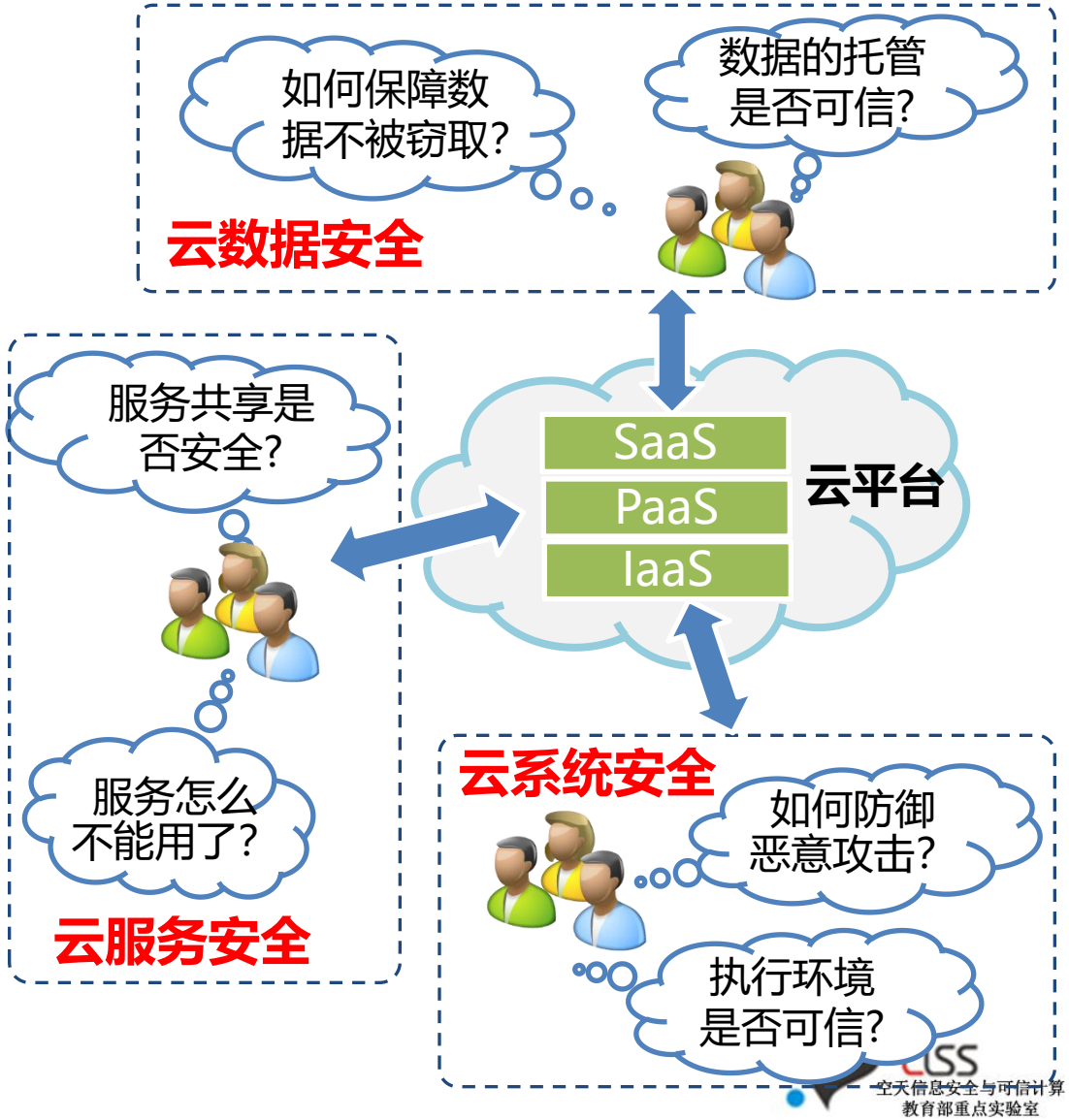
银行的保险箱

云计算的体系结构



开源云平台
OpenStack

关键安全问题



问题 1-云系统的安全构建:

为解决云计算系统动态复杂性带来的不确定性安全问题与用户所需要的可感知安全性保障之间的矛盾

问题 2-云服务的安全共享:

为解决云环境服务效率最大化与海量租户多样化安全需求之间的矛盾

问题 3-云数据的安全可控:

为解决云环境中数据托管特征与租户数据安全可控需求之间的矛盾

关键安全问题

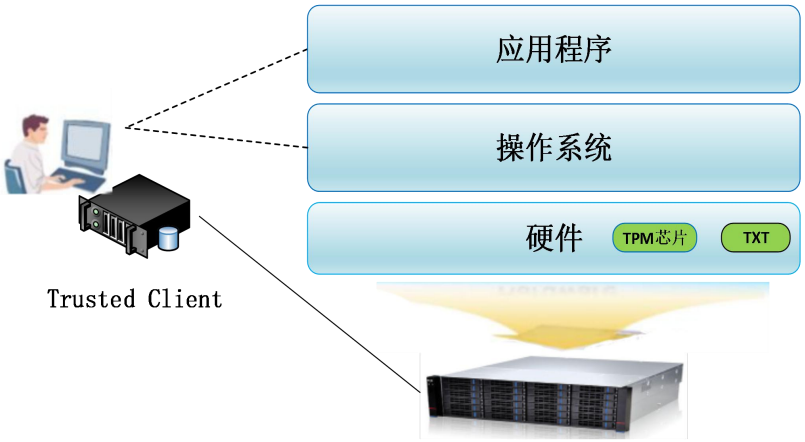
- 云系统安全，如共享环境下的隔离机制、访问控制、侧信道
- 云数据安全，如云加密、密文检索
- 外包服务的安全

基于TPM 2.0的虚拟可信根及其安全增强

问题和思路

- 如何利用可信计算技术为云虚拟机提供可信根，对虚拟机系统行为和数据进行可信验证

用户的数据存储在云平台中



普通可信服务器

空天信息安全与可信计算
教育部重点实验室

基于TPM 2.0的虚拟可信根及其安全增强

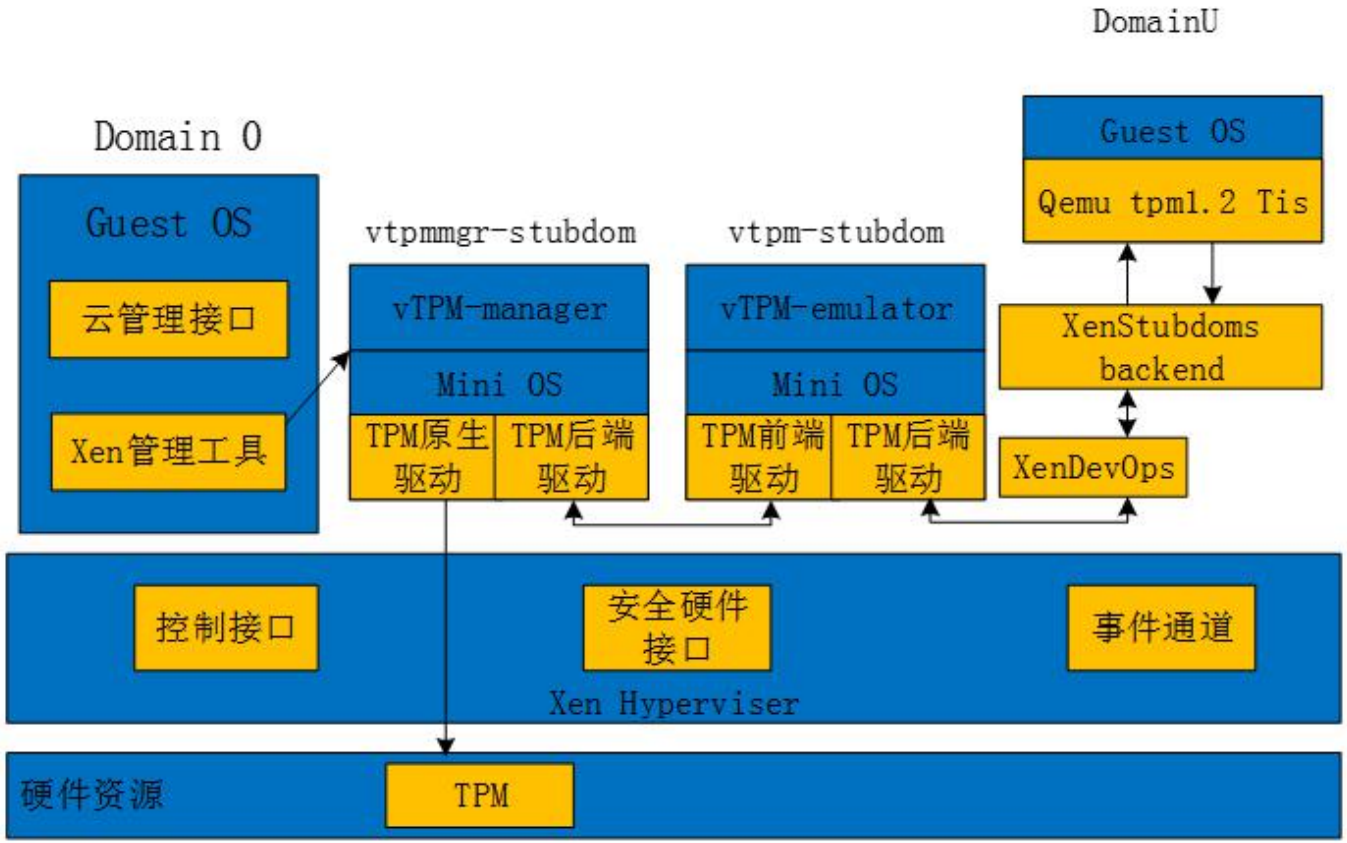
研究目标

通过实现TPM2.0设备的虚拟化构建虚拟可信平台解决云计算平台虚拟计算环境下的可信服务问题。通过云平台来进行虚拟化服务管理和虚拟机实例管理，构建虚拟可信平台模块解决虚拟计算环境下的可信服务，并为虚拟域提供vTPM2.0设备以及vTPM2.0的完整功能。

- 研究虚拟可信平台vTPM2.0的实现架构、迁移机制、安全性增强机制；实现云管理平台中虚拟机创建过程的vTPM2.0定制。为虚拟域提供虚拟TPM2.0完整功能；
- 虚拟可信平台模块vTPM2.0为每个虚拟机提供保护敏感信息、存储虚拟环境度量值、提供远程证明等功能。

基于TPM 2.0的虚拟可信根及其安全增强

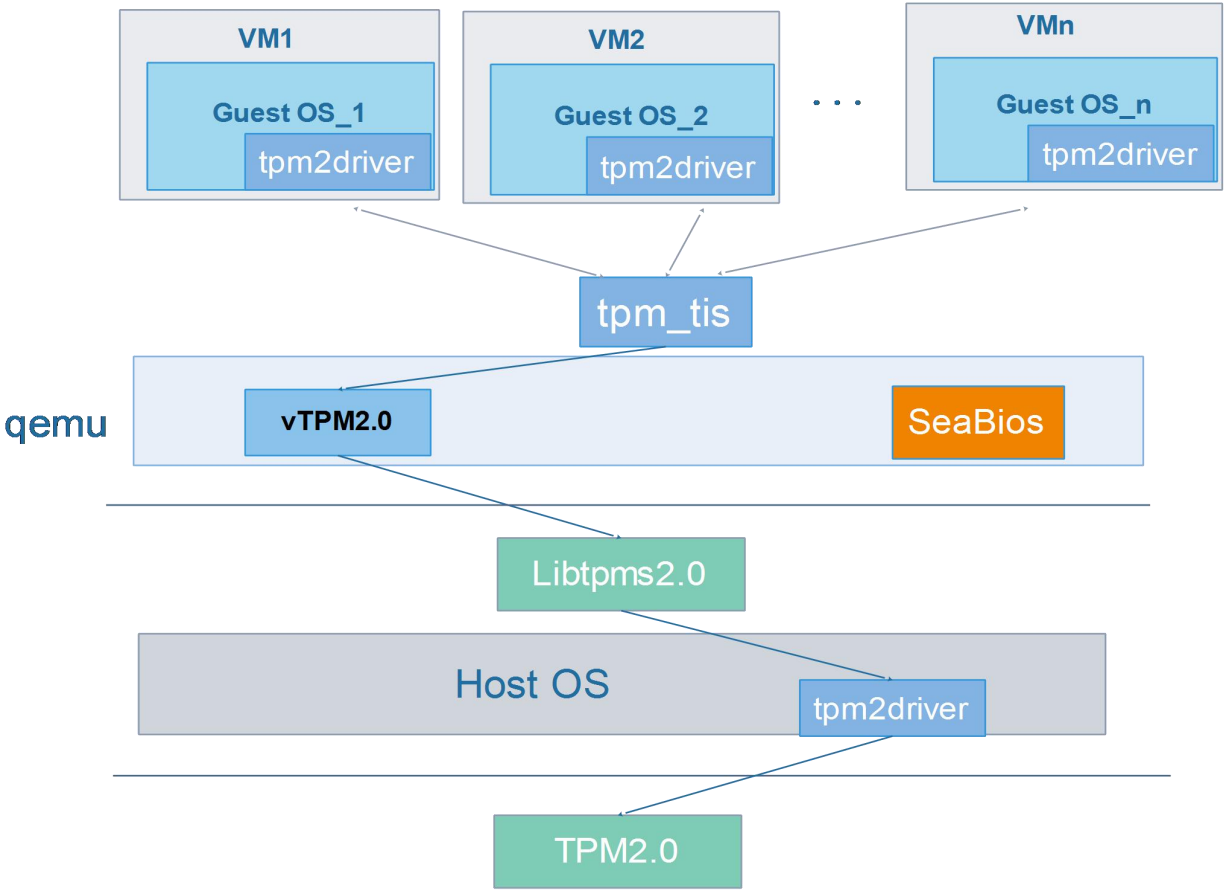
（1）基于Xen架构的vTPM 2.0设计与实现



基于Xen的vTPM 2.0架构

基于TPM 2.0的虚拟可信根及其安全增强

（2）基于KVM的vTPM 2.0设计与实现

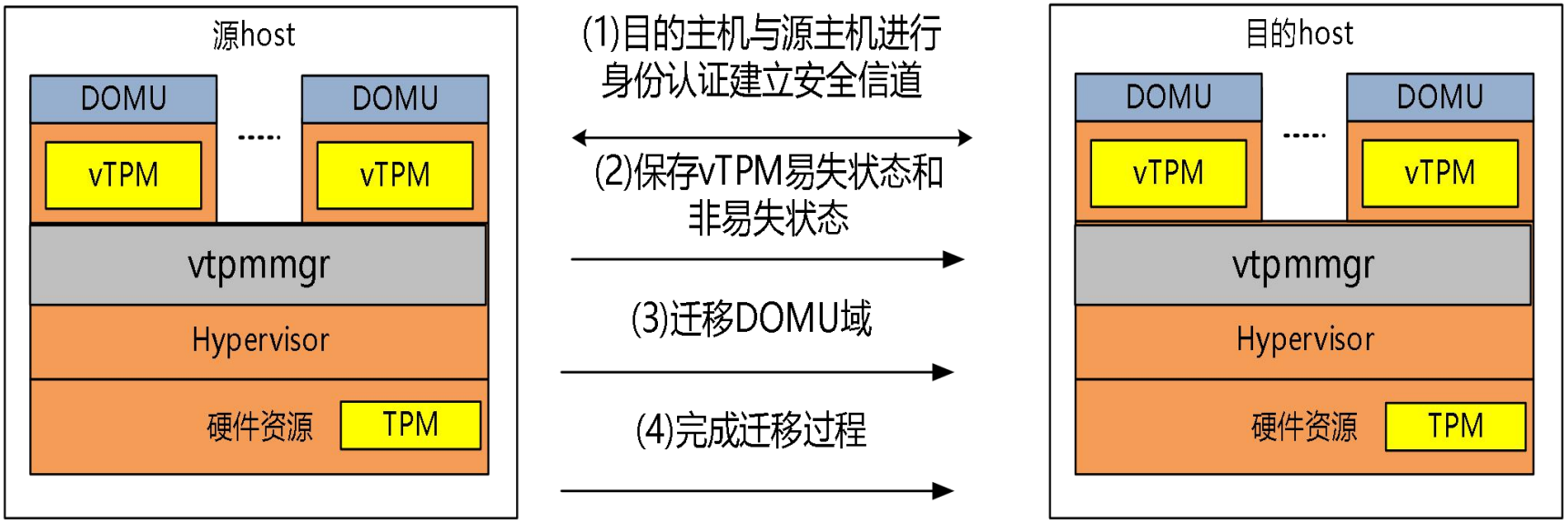


基于KVM的vTPM 2.0架构

LISS
空天信息安全与可信计算
教育部重点实验室

基于TPM 2.0的虚拟可信根及其安全增强

（3）虚拟vTPM 的在线迁移



可信虚拟机迁移

LISS
空天信息安全与可信计算
教育部重点实验室

安卓安全漏洞

www.cnnvd.org.cn/web/vulnerability/queryLds.tag?pageno=1&repairLd=

CNNVD 国家信息安全漏洞库

首页 漏洞信息 补丁信息 网安时情 数据立方 漏洞报告 漏洞预警 兼容

漏洞信息

Android System 安全漏洞 CNNVD-202005-095	2020-05-05
Android System 安全漏洞 CNNVD-202005-094	2020-05-05
Android System 安全漏洞 CNNVD-202005-093	2020-05-05
Android System 安全漏洞 CNNVD-202005-092	2020-05-05
Android Media framework 安全漏洞 CNNVD-202005-091	2020-05-05
Android System 安全漏洞 CNNVD-202005-090	2020-05-05

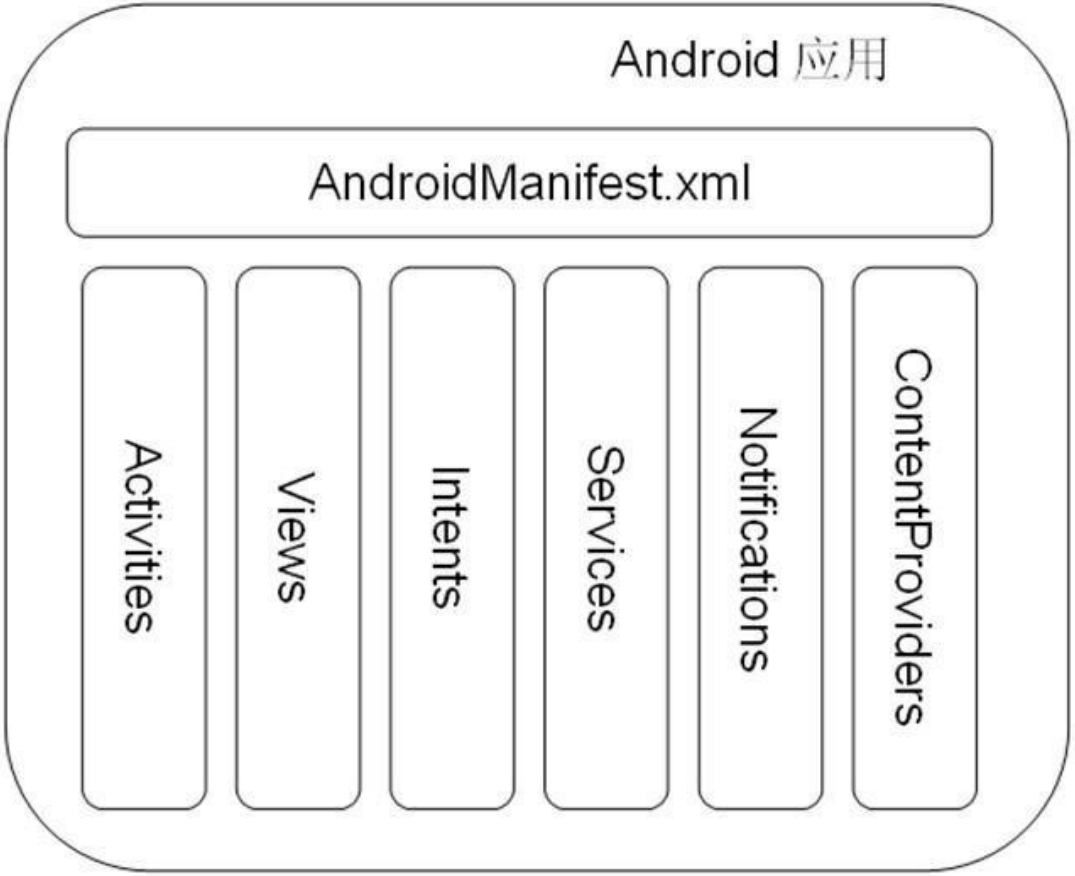
5月份22个漏洞，一共5117个漏洞

空天信息安全与可信计算教育部重点实验室

典型的安全问题

- 组件间通信安全
- 数据泄露
- 伪造通信
- 隐私问题

安卓应用组成

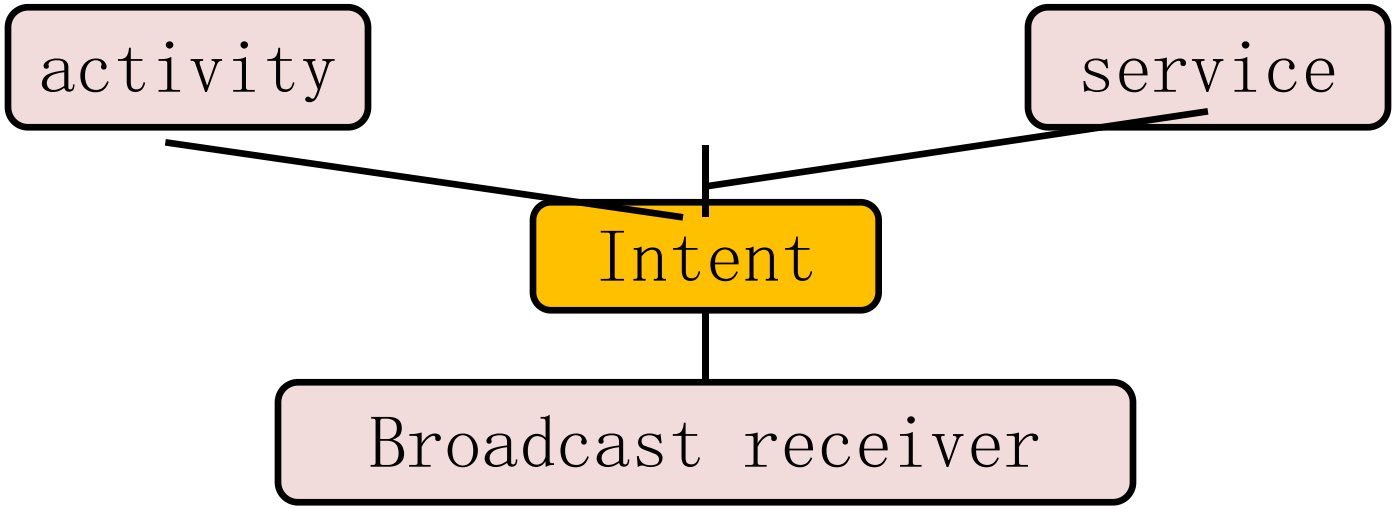


四大核心组件：

- Activity
- 服务
- 广播接收器
- 内容提供程序

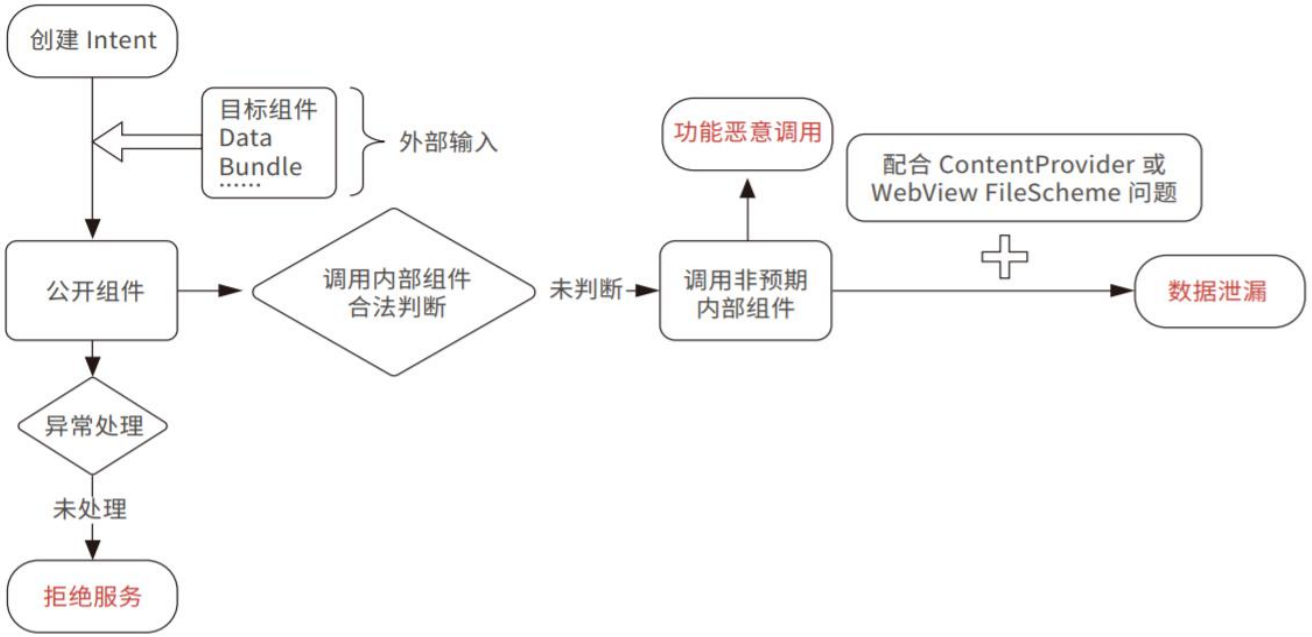
Intent

- 类似于消息、事件通知
- Activity、Service、broadcast receiver之间的桥梁
- Intent不仅可用于应用程序之间，也可用于应用程序内部的Activity/Service之间的交互



组件间通信安全

- 如果开发人员缺少对外部输入的校验和异常处理，通过构造异常Intent输入数据，则可以造成拒绝服务攻击。
- 如果公开组件可以根据输入数据，生成 Intent来启动内部组件，同时 Intent 数据访问未被限制，外部输入控制新生成 Intent 的目标组件、Data、Bundle 等参数，可以访问内部非公开组件，造成功能被恶意调用。



组件间通信安全

以 Intent 转发创建 Intent 被利用的安全风险为例，如下图，在某应用中存在导出组件 ClientUiProxyActivity：

```
//com.[illegible].ui.client.ClientUiProxyActivity
protected final void onCreate(Bundle bundle) {
        super.onCreate(bundle);
        Intent intent = (Intent) getIntent().getParcelableExtra(
            "com.[illegible].PROXY_INTENT");
        if (intent != null) {
            startActivityForResult(intent, 1000);
            return;
        }
}
```

通过控制 Intent 中的 PROXY_INTENT 参数，可以控制 startActiviy 的整个 Intent，以该应用权限启动任意 Activity。

数据泄露--调试信息和日志文件泄露

- 调试信息和日志文件暴露重要数据
- 文件分享存在隐患
- ContentProvider数据接口需多重防护
- WebView FileScheme疏忽造成应用克隆威胁
- 其他数据泄露

伪造-伪造通信

常见伪造通信类型有：进程内组件间的Intent通信、远程Service通信、Socket的IPC通信等，如果没有严格的通信校验，攻击者通过伪造通信数据，达到不可告人的目的。

示例：通过暴露的远程service，伪造通信数据，实现应用程序远程下载和安装

```
private ServiceConnection conn = new ServiceConnection() {

    @Override
    public void onServiceDisconnected(ComponentName name) {
        // TODO Auto-generated method stub
        conn = null;
    }

    @Override
    public void onServiceConnected(ComponentName name, IBinder service) {
        // TODO Auto-generated method stub

        DownloadService ser = DownloadService.Stub.asInterface(service);
        try {
            ser.a(14, "[redacted]ja.apk");
        } catch (Exception e) {
            Log.e("NNNN", e.getMessage());
        }
    }
```

伪造-伪造通信

```
public void run()
{
    try
    {

        Socket s=new Socket(IpAddress,Port);

        OutputStream os = s.getOutputStream();

        byte[] precode = new byte[4];
        short st = (short) 20[redacted]
        precode[3] = (byte) (st >> [redacted];
        precode[2] = (byte) (st >> [redacted];
        precode[1] = (byte) (st >> [redacted]);
        precode[0] = (byte) (st >> [redacted]);
        os.write(precode);
        os.flush();

        byte[] procode = new byte[4];
        short stc = (short) [redacted];
        procode[3] = (byte) (stc >> [redacted];
        procode[2] = (byte) (stc >> [redacted];
        procode[1] = (byte) (stc >> [redacted]);
        procode[0] = (byte) (stc >> [redacted]);
        os.write(procode);
        os.flush();

          os.close();

        DataInputStream is = new DataInputStream(s.getInputStream());
        int op = is.readInt();
        int len = is.readInt();
        byte []bs = new byte[len];
        is.read(bs, 0, 320);
        Log.e("NNNN", "respone: " + op + ":" + len + ":" + new String(bs));
```

伪造socket通信数据，实现应用特定指令执行，盗取敏感数据。

防护手段：协议数据要加密，通信访问要验证。

伪造--伪造文件

文件权限和校验的失控，让攻击者有机可乘。代码文件存放在公共目录，程序没有对文件进行完整性校验，就很容易造成应用的代码被劫持，从而进行注入。

实例：sdcard公共目录下的so文件

```
shell@t03gchnduos:/ $ ll /sdcard/And[redacted]/download
-rw-rw-r-- root     sdcard_rw     6055 2017-03-20 20:26 __zone6.cfg
drwxrwxr-x root     sdcard_rw          2017-03-20 20:26 adv
drwxrwxr-x root     sdcard_rw          2017-03-20 20:34 backup
-rw-rw-r-- root     sdcard_rw    13432 2017-03-20 20:19 lib[redacted]r_1.so
-rw-rw-r-- root     sdcard_rw        0 2017-03-20 20:21 tag
```

隐私问题

- App 违法违规收集使用个人信息主要体现在 App 过度收集核心隐私权限。
- App 获取产品功能并不需要的权限， 另一方面，没有按照隐私声明向用户保持权限获取的公开透明。

- 防护手段：

移动应用开发厂商应合理申请所需的隐私数据，并通过详细的隐私条款与用户说明所需隐私数据的用途，在使用相关数据过程中，也应加强数据安全保护能力，避免被恶意窃取或者信息泄漏。

研究方向

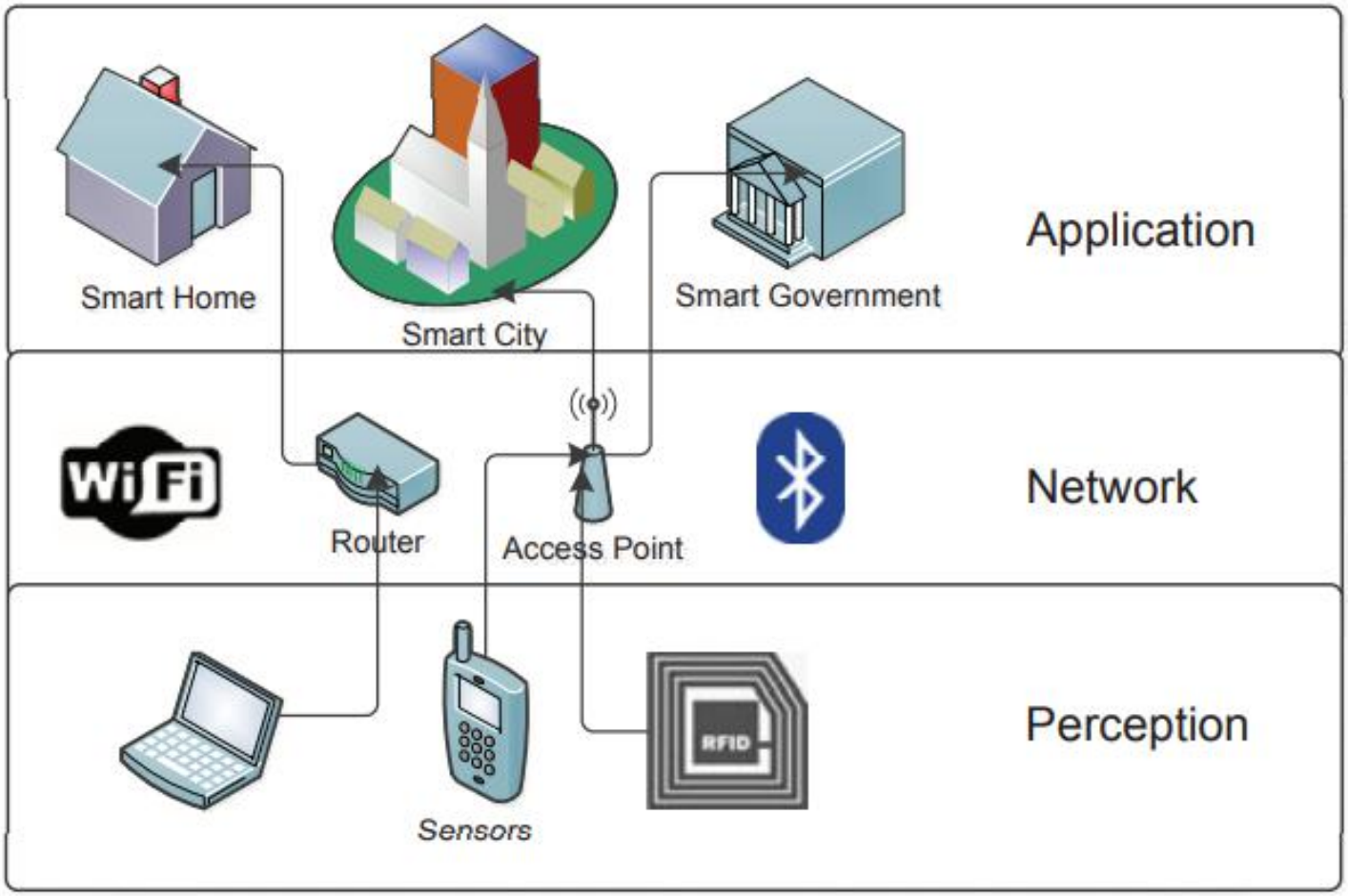
- 访问控制
  - ✓Intent、Capbility、SEAndroid
- 进程间通信安全
  - ✓Binder安全
- 信息流分析
  - ✓静态污点跟踪、动态污点跟踪、进程间通信安全
- 沙箱安全
  - ✓Dex、ART虚拟机安全
- 隐私保护
  - ✓隐私策略、隐私信息泄露、差分隐私、Trustzone
- APP安全机制
  - ✓反混淆、重打包分析、加壳和脱壳分析

LISS
空天信息安全与可信计算
教育部重点实验室

其它研究热点

- 物联网(IOT，Internet of things)安全
- 工业控制系统安全

物联网体系架构


Smart Home
Smart City
Smart Government
Application
WiFi
Router
Access Point
Network
Sensors
RFID
Perception

物联网安全

- 物联网安全
  - ✓ 物联网攻击方法
  - ✓ 访问控制规则
    - SmartAPP和设备间、设备和设备之间
  - ✓ 设备和云端通信的安全
  - ✓ 固件漏洞挖掘
  - ✓ 设备安全评估
  - ✓ 物理层通信安全

系统安全研究基础

- 计算机理论和技术
  - ✓ 计算机组成原理、操作系统、编译原理、计算机网络通信
- 安全理论和技术
  - ✓ 密码学、访问控制、软件安全分析技术（逆向分析、污点跟踪、符号执行、软件加固）、模糊测试和漏洞挖掘、可信计算与TEE
- 新理论和新技术
  - ✓ 人工智能和深度学习

LISS
空天信息安全与可信计算
教育部重点实验室

谢　　谢！

LISS
空天信息安全与可信计算
教育部重点实验室